DAE 12-MONTH COHORT

AccessGuard Health

Securing a hospital's identities, from the directory to the cloud



Created by Sabitha S Karanavar

Healthcare Identity and Access Management portfolio project

AGENDA

Our story in five steps

01 **Why IAM matters**
What identity and access management is, and the problem it solves

02 **Why I built this**
From web developer to access-control builder

03 **Designing the hospital**
30 employees, 10 roles, one clear set of rules

04 **Building it in Azure**
Architecture, security layers and a live nurse onboarding

05 **Walk-through and what's next**
The demo video, key takeaways and my next steps

THE QUESTION

A hospital with 30 employees. Who should have access to what?

This project answers it, end to end.

What is IAM, and why does it matter?

Identity and Access Management: the right people get the right access, to the right systems, at the right time.



01

Identification

Who are you?



02

Authentication

Prove it.



03

Authorization

What are you allowed to do?



04

Accounting

What did you do?



05

Administration

Manage joiners, movers and leavers.



Identity is the new firewall.

Attackers don't break in, they log in: stolen passwords, abused sessions, compromised accounts and weak permissions.

THE PROBLEM

What goes wrong without it, and the fix

THE RISK	HOW IAM SOLVES IT
Everyone gets "just in case" access	Least privilege: access is designed by role
Leavers keep their accounts	Joiner, mover, leaver process: disabled the same day
A password alone guards patient records	MFA and Conditional Access check every sign-in
Nobody can prove who accessed what	Tickets, logs and access reviews leave a trail

IAM INCLUDES

MFA · Single sign-on · Privileged access · Joiner / leaver process · Access reviews · RBAC

If identity fails, everything else becomes weaker.

WHY I BUILT IT

A developer who now builds access controls

BACKGROUND

- **WordPress Developer, freelance**
  2019 to present · plugins, themes, MySQL
- **Associate Software Developer**
  2012 to 2013 · PHP, MySQL, JavaScript
- **Software Engineer**
  2011 to 2012

Master's degree in Computer Science · Python, PHP, Git



High stakes

Patient data is private and tightly regulated (HIPAA), so access has to be right.



My skills meet here

IAM joins what I know from development with security.



Proof, not promises

A hospital I designed, built and tested is evidence I can show employers.

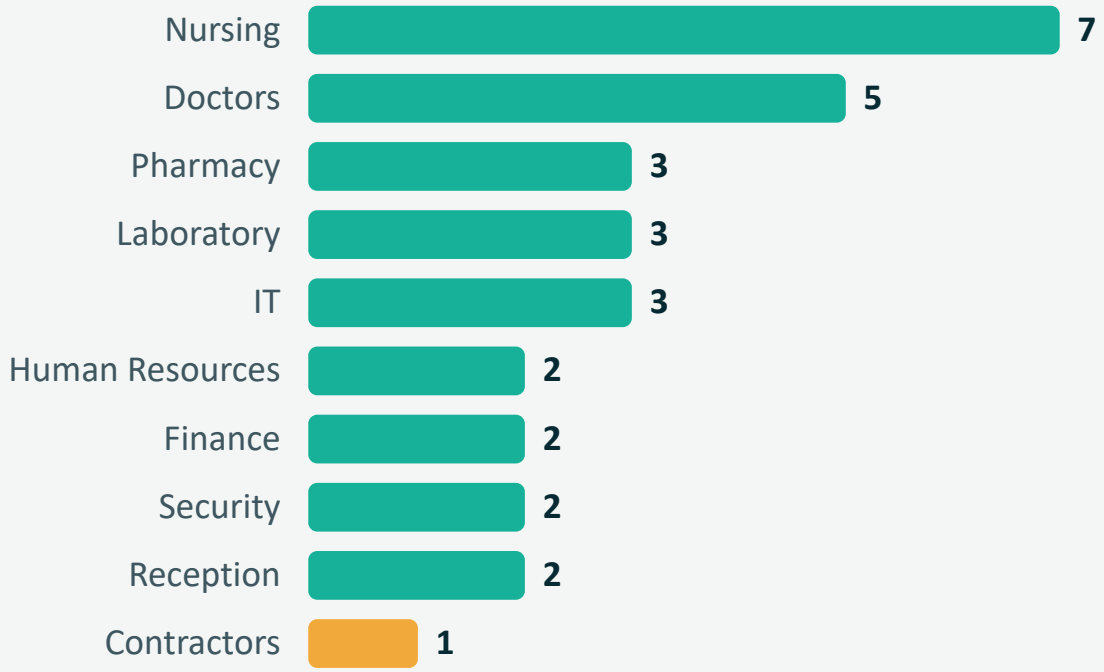
The scenario: Horizon Valley Medical Center

30 employees

10 departments

10 roles

10 simulated apps



THE 10 SIMULATED APPLICATIONS

EHR · Pharmacy · Lab (LIS) · HR Portal · Payroll · Finance ERP · IT Admin · Security Portal · Scheduling · VPN

THE DESIGN

Seven rules govern every access decision

1
One primary role per employee

2
Access comes from security groups, never directly to users

3
Least privilege: only the access the role requires

4
Contractors get temporary accounts with limited permissions

5
IT administrators approve all access requests

6
HR tells IT when people join, transfer or leave

7
Departing employees are disabled the same day

Audit ready: each change leaves a ticket

PREDICTABLE NAMES

```
SG-<Department>-<Application>-<Access>
```

A group name tells you who, what and how much.

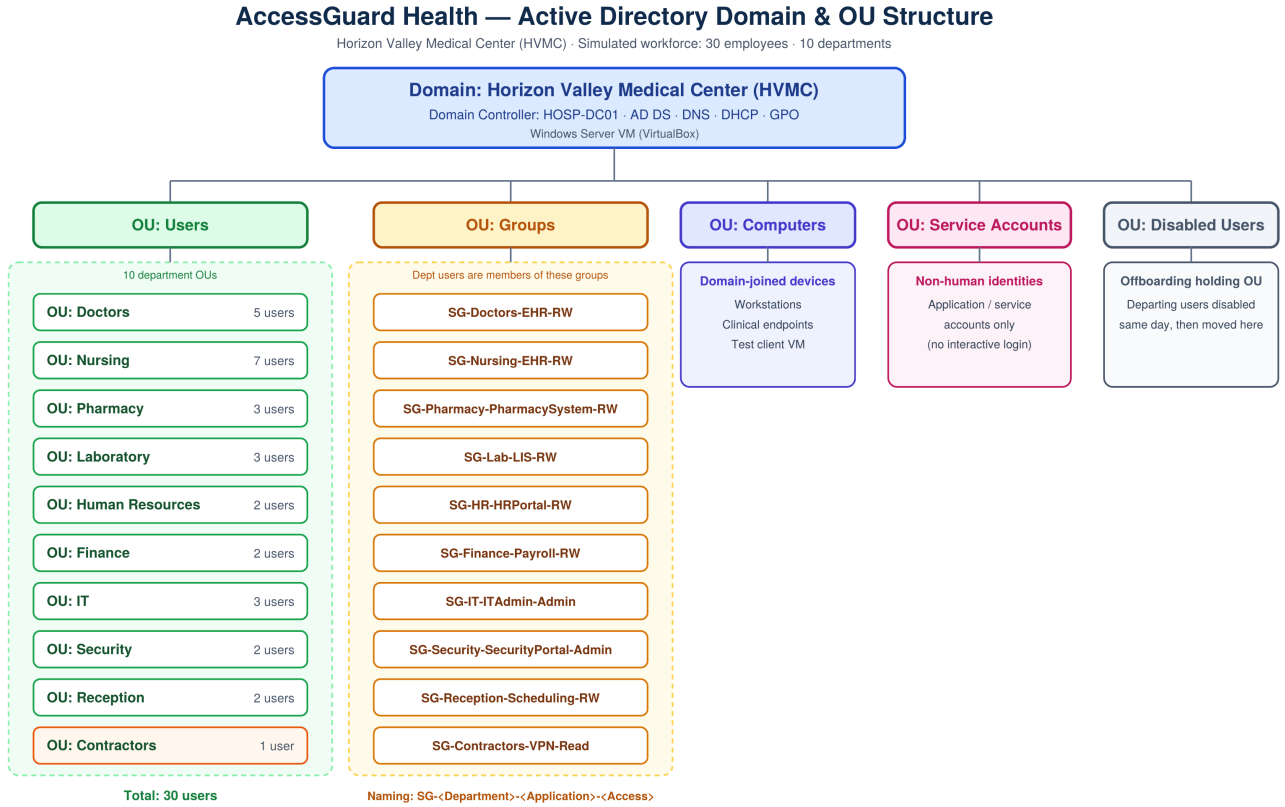
SG-Doctors-EHR-RW
Doctors: read and write the EHR

SG-Pharmacy-PharmacySystem-RW
Pharmacy: dispensing system

SG-Security-SecurityPortal-Admin
Security team: portal admin

SG-Contractors-VPN-Read
Contractors: VPN access only

How identities are organised



Five containers

Users, Groups, Computers, Service Accounts and a Disabled Users holding area.

10 department OUs

30 users, each placed in one department.

Access through groups

Department users are members of security groups. Nobody is granted access directly.

THE DESIGN

Access is designed by role, not by person

Role	EHR	Pharm	LIS	Payroll	HR	ERP	IT	Sec	Sched
Doctor	RW	R	R	–	–	–	–	–	–
Nurse	RW	R	R	–	–	–	–	–	–
Pharmacist	R	RW	–	–	–	–	–	–	–
Lab Technician	R	–	RW	–	–	–	–	–	–
Human Resources	–	–	–	RW	RW	–	–	–	–
Finance	–	–	–	RW	R	RW	–	–	–
IT Administrator	R	R	R	–	–	–	A	A	A
Security Officer	–	–	–	–	–	–	–	A	–
Receptionist	R	–	–	–	–	–	–	–	RW
Contractor	L	–	–	–	–	–	L	–	–

RW read and write R read A admin L limited – no access

Two identity systems, one common mistake

Entra ID is not Active Directory hosted in the cloud. Treating it that way leaves real security gaps.

ON-PREMISES

Active Directory

- Domain controllers in your own data center
- Forests, domains and OUs
- Kerberos, NTLM and LDAP
- Group Policy for Windows machines

IN THE CLOUD

Microsoft Entra ID

- Microsoft runs the tenant: no servers to patch
- Flat: users, groups, administrative units
- OAuth 2.0, OpenID Connect and SAML
- Managed through Graph and Intune

CONDITIONAL ACCESS AND ZERO TRUST

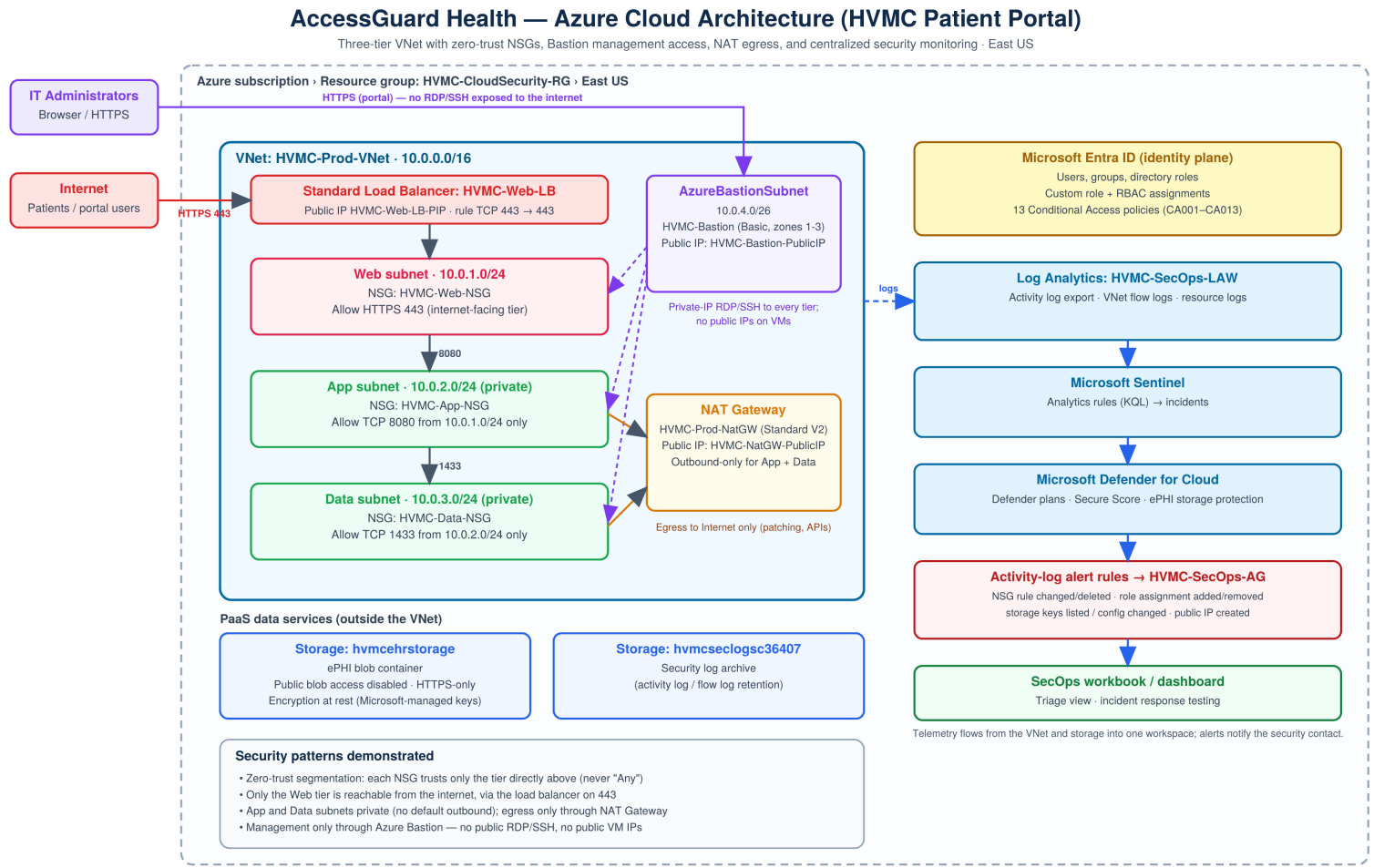
1 · Signals
User, device, location, app, risk

2 · Policy
Require MFA or a compliant device, or block

3 · Result
Granted, limited or blocked at every sign-in

Never trust, always verify.

How the hospital is secured in Azure



Three tiers, zero trust

Only the web tier faces the internet. Each tier trusts just the one above it.

No public RDP or SSH

Admins reach every server through Azure Bastion.

Watched end to end

Logs flow into Sentinel, which raises alerts and feeds a live dashboard.

THE BUILD

Securing a hospital in Azure: what I built

Every layer implemented, tested and evidenced, at $0 for identity and security tooling.

STEP 1

Data protection

Encrypted storage, Defender malware scanning

STEP 2

Network security

3-tier VNet, firewall rules, Azure Bastion

STEP 3

Identity & access

Entra ID, MFA, least-privilege nurse role

STEP 4

Monitoring

Central logs, 9 alerts, Sentinel threat detection, live dashboard

STEP 5

Incident response

5-phase playbook, 8 of 8 incidents closed

STEP 6

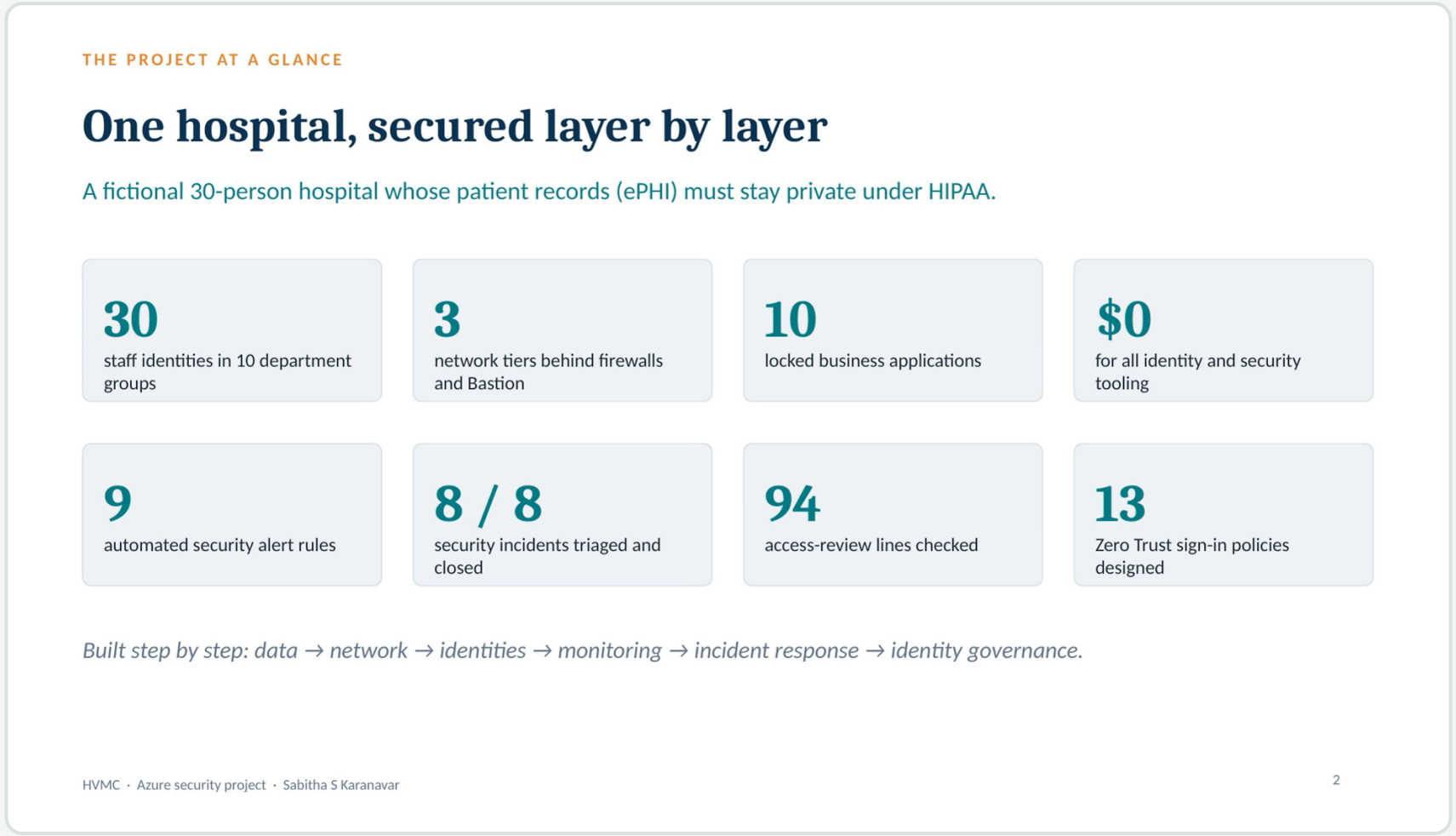
Identity governance

Role groups, joiners and leavers, 93 of 94 access lines confirmed

Zero Trust design: 13 Conditional Access policies designed, saved as deployable files and ready to switch on with a licence.

SEE IT IN ACTION

Walk through



THE DEMO

Monday, 8 a.m.: onboarding a new nurse

Six ticketed steps from HR's email to verified access. It is one turn of the joiner, mover, leaver cycle.

1 HR notifies IT of the new hire

2 IT approves and creates the account

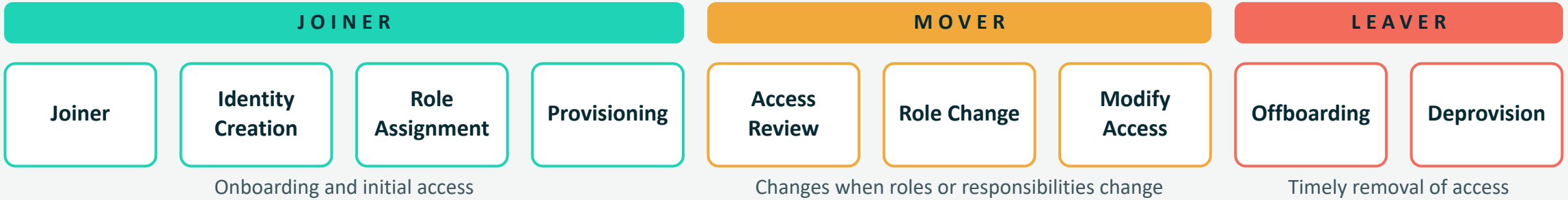
3 Add to the nursing security group

4 Enroll MFA for sign-in

5 Verify access works, and only that access

6 Close the ticket with evidence

THE LIFECYCLE BEHIND EVERY ACCESS CHANGE



What the employer should see: the nurse reaches the EHR through group membership, with no direct grants and no payroll access.

Protecting identity is protecting the business

KEY TAKEAWAYS

- IAM protects organizational identities
- Authentication verifies identity; authorization grants permissions
- RBAC is a foundation of enterprise IAM
- Identity governance improves compliance
- IAM tools automate the identity lifecycle
- IAM analysts help ensure secure, appropriate access

FINISHING BY NOVEMBER 5

- PowerShell automation for account creation and removal
- A second access review to compare findings
- Build the on-premises Active Directory infrastructure setup

ROLES I'M SEEKING

IAM or IT Security Analyst · Junior IAM Analyst

Healthcare, university and government teams · Connecticut, New York, New Jersey or remote

Thank You

From web development to healthcare IAM security, let's connect.

GITHUB PORTFOLIO

All Semester 1–3 projects

github.com/sabi-s/dae-6-month-Sabi

LINKEDIN

Let's connect professionally

linkedin.com/in/sabitha-s-49ba9b428

Created by Sabitha S Karanavar

Python Developer | IAM Analyst · DAE 12-month Cohort